

System Card:

SENTINEL

Preview

April 10, 2026

github.com/MuzeenMir/sentinel

Abstract

This System Card describes SENTINEL, an enterprise-grade, AI-powered security platform for real-time threat detection, automated response, and compliance management. SENTINEL combines a supervised/unsupervised detection ensemble (XGBoost, LSTM, Isolation Forest, Autoencoder), a deep reinforcement learning (PPO) policy agent, eBPF/XDP data-path enforcement, a host intrusion detection system, a hardening service aligned to the CIS benchmarks, and a compliance engine covering SOC 2, ISO 27001, GDPR, HIPAA, NIST CSF, and PCI-DSS.

This document is modelled on the structure of Anthropic's Claude Mythos Preview System Card (April 7, 2026). Its purpose is to document SENTINEL's capabilities, failure modes, safeguards, and open risks in a single authoritative artefact — the kind of document frontier-AI vendors are now expected to publish, and the kind of document any serious security product should be willing to publish about itself.

SENTINEL does not exhibit general-purpose frontier capabilities. It is a narrow, purpose-built defensive system. The risks associated with it are correspondingly narrower: detector drift, false positives on live traffic, reward hacking of the PPO agent, adversarial evasion of the ensemble, and over-aggressive automated enforcement. This card takes each in turn.

This is a preview. Several sections — notably Capability benchmarks (§6) and the Alignment assessment of the PPO agent (§4) — report current targets rather than measured production results, and are marked as such.

Contents

Abstract	3
1 Introduction	5
1.1 Platform characteristics	5
1.2 Release decision process	6
2 Risk tier evaluations	7
2.1 Risk assessment process	7
2.2 Detection risk tier (D-1)	8
2.3 Policy risk tier (DRL-1)	9
2.4 Compliance risk tier (C-1)	10
3 Cyber defence capabilities	11
3.1 Introduction	11
3.2 Mitigations	11
3.3 Detection benchmarks	12
3.4 Response benchmarks	13
4 Alignment assessment	14
4.1 Scope and method	14
4.2 Reward hacking review (PPO agent)	15
4.3 Adversarial evasion of detectors	16
4.4 Human-override and auto-rollback	17
5 Operator trust assessment	18
6 Capabilities	19
6.1 Per-detector performance targets	19
6.2 End-to-end latency	20
7 Impressions	21
8 Appendix	22
8.1 Safeguards and controls	22
8.2 Compliance mapping (excerpt)	23
8.3 API surface	24

1 Introduction

SENTINEL is an enterprise-grade security platform for real-time threat detection, automated response, and compliance management. Unlike a frontier large language model, SENTINEL is a narrow, purpose-built system: its job is to move a server or a fleet from a default install toward a hardened, monitored, least-privilege posture, and to keep it there under load and under attack.

SENTINEL's design centre is defence-in-depth. Traffic enters the platform via a data collector that captures flows from raw sockets, NetFlow, sFlow, and a high-speed XDP path; events are normalised to a Common Information Model, published to Kafka, and processed by Flink jobs that extract statistical, behavioural, and contextual features. The feature vectors flow into an ensemble of supervised and unsupervised detectors, whose outputs are consumed by a PPO deep-reinforcement-learning agent that recommends a firewall action. Actions flow through a policy orchestrator that validates and dispatches them to firewall adapters (iptables, AWS Security Groups, more to follow). Operators see the full state of the system through a React/TypeScript admin console, with Grafana for metrics, Prometheus for scraping, and the compliance engine for audit-ready evidence.

1.1 Platform characteristics

SENTINEL is built as a microservices stack. Each service owns one concern and talks to others through a central API gateway (for synchronous requests) and Kafka (for asynchronous event streams). The core services are:

- **api-gateway** — authentication, rate limiting, request routing.
- **auth-service** — JWT issuance, bcrypt password storage, RBAC, MFA (TOTP, FIDO2).
- **ai-engine** — XGBoost, LSTM, Isolation Forest, Autoencoder, stacking ensemble.
- **drl-engine** — PPO agent for policy decisions.
- **policy-orchestrator** — rule generation, validation, conflict detection, dispatch.
- **xai-service** — SHAP-based explanations on every detection.
- **compliance-engine** — framework assessments against SOC 2, ISO 27001, GDPR, HIPAA, NIST CSF, PCI-DSS.
- **alert-service** — alert lifecycle, email/Slack notification, escalation.
- **data-collector / xdp-collector** — ingress and high-speed flow capture.
- **hids-agent** — host intrusion detection using eBPF tracepoints and file integrity monitoring.
- **hardening-service** — CIS benchmark scanning, eBPF LSM enforcement, rollback.

Supporting infrastructure: PostgreSQL for relational state, Redis for caching and blacklists, Kafka (MSK in AWS deployments) for event streams, TimescaleDB optionally for long-horizon metric storage, and S3 for model artefact storage. Infrastructure-as-code is provided as Terraform for AWS (VPC, RDS, ElastiCache, MSK, ECS Fargate, WAF, CloudWatch alarms).

1.2 Release decision process

SENTINEL is open, self-hosted software; there is no gated release mechanism in the sense that Anthropic operates for frontier models. However, we adopt three explicit *product risk tiers* (D-1, DRL-1, C-1) that a release candidate must satisfy before being tagged as stable. These are described in §2. A candidate that fails any of the three is held back to the edge channel.

This card is published with each tagged release. It replaces, and supersedes, the older STATUS-AND-NEXT-STEPS.md file as the authoritative statement of what SENTINEL can and cannot do at this point in time.

2 Risk tier evaluations

2.1 Risk assessment process

A frontier-model system card is organised around Responsible Scaling Policy thresholds — capability levels a model should not cross without proportional mitigations. SENTINEL is not a frontier model and has no catastrophic-risk thresholds in the Anthropic sense, but the shape of the question is still useful: what claims is the project willing to stand behind, and what mitigations does it rely on to hold those claims true?

We define three **product risk tiers**. Each tier is a bundle of (a) a capability claim, (b) a mitigation claim, and (c) an evidence requirement. A tier is *not crossed* if the claim is falsified in testing; crossing a tier has release consequences.

Tier	Claim	Mitigation	Evidence
D-1 Detection	Ensemble weighted F1 ≥ 0.90 on held-out subset of a mixed public benchmark (CIC-IDS2017, UNSW-NB15) augmented with internally generated adversarial flows.	Ensemble threshold ≥ 0.95 on inference p95 ≤ 5 ms per sample on the XGBoost path, ≤ 10 ms on the LSTM sequence path.	Ensemble threshold ≥ 0.95 on inference p95 ≤ 5 ms per sample on the XGBoost path, ≤ 10 ms on the LSTM sequence path.
DRL-1 Policy	PPO agent causes $< 1\%$ false block on confirmed threat, $< 0.5\%$ false allow on benign traffic.	Shadow model compliance score ≥ 0.95 on inference p95 ≤ 5 ms per sample on the XGBoost path, ≤ 10 ms on the LSTM sequence path.	Shadow model compliance score ≥ 0.95 on inference p95 ≤ 5 ms per sample on the XGBoost path, ≤ 10 ms on the LSTM sequence path.
C-1 Compliance	100% of in-scope SOC 2 CC controls are implemented and monitored.	Shadow model compliance score ≥ 0.95 on inference p95 ≤ 5 ms per sample on the XGBoost path, ≤ 10 ms on the LSTM sequence path.	Shadow model compliance score ≥ 0.95 on inference p95 ≤ 5 ms per sample on the XGBoost path, ≤ 10 ms on the LSTM sequence path.

[Table 2.1.A] SENTINEL product risk tiers.

2.2 Detection risk tier (D-1)

D-1 concerns the ensemble detector's ability to correctly classify network traffic and host events as benign or malicious. The claim is operationalised against a held-out subset of a mixed public benchmark (CIC-IDS2017, UNSW-NB15) augmented with internally generated adversarial flows.

SENTINEL's per-detector target table is reproduced in §6. At the ensemble level, the D-1 threshold requires weighted F1 ≥ 0.90 , precision ≥ 0.90 , recall ≥ 0.88 , and inference p95 ≤ 5 ms per sample on the XGBoost path, ≤ 10 ms on the LSTM sequence path.

Status in this preview: the targets are documented in ml-models.md; production-scored results are not yet included in this card and will be reported in the next release.

2.3 Policy risk tier (DRL-1)

DRL-1 concerns the PPO agent's action selection. The agent's action space is {ALLOW, DENY, RATE_LIMIT, MONITOR, QUARANTINE, REDIRECT}, and its shaped reward function is + 1.0 for blocking a confirmed threat, − 1.0 for false positives, − 0.5 for allowing a confirmed threat, + 0.2 for correct benign passthrough, a latency-impact penalty, and a compliance bonus.

DRL-1 is where SENTINEL most resembles the alignment problems that frontier labs worry about. An agent trained on a shaped reward can learn to game it; a live-fire policy agent can cause real damage if its mistakes are cheap and its overrides are expensive. We therefore treat DRL-1 the way Mythos treats its autonomy thresholds, with explicit staged rollout, a reward-hacking audit (§4.2), and mandatory shadow-mode evidence before a new PPO checkpoint reaches enforcement.

2.4 Compliance risk tier (C-1)

C-1 concerns the compliance engine's ability to continuously produce audit evidence for SOC 2 Trust Services Criteria. The claim is that 100% of in-scope Common Criteria controls (CC1–CC8) have an automated evidence collector that runs at least daily and whose output is retained for at least 12 months. The current in-repo mapping covers CC1.1, CC2.1, CC3.1, CC5.1, CC6.1–CC6.8, CC7.1–CC7.4, CC8.1 (14 controls); SENTINEL additionally maps Availability (A1.1–A1.3) and Confidentiality (C1.1–C1.2).

3 Cyber defence capabilities

3.1 Introduction

SENTINEL is not an offensive tool and makes no claim to vulnerability discovery. Its cyber capability story is defensive: high-throughput ingestion, low-latency detection, policy generation with human-interpretable explanations, and in-band enforcement through the policy orchestrator.

3.2 Mitigations

SENTINEL's platform-level mitigations — the controls that protect SENTINEL *itself* from compromise — are layered:

- **Authentication:** JWT (HS256, 24h access / 30d refresh), bcrypt password hashing, account lockout after 5 failed attempts.
- **MFA:** TOTP and FIDO2/WebAuthn; OIDC and SAML federation; SCIM provisioning.
- **RBAC:** five predefined roles with least-privilege grants; admin-only writes on destructive endpoints.
- **Input validation:** per-service validators; parameterized SQL.
- **Rate limiting:** per-IP and per-user; configured at the API gateway.
- **Transport security:** TLS terminated at reverse-proxy; strict cipher suites.
- **Secrets management:** environment variables and .env.example placeholders; no secrets in source; AWS Secrets Manager/Vault in production deployments.
- **Runtime enforcement:** eBPF LSM hooks; XDP drop for known bad sources; host integrity monitoring by the HIDS agent.
- **Audit logging:** structured logs shipped to Elasticsearch / S3 with correlation IDs.

3.3 Detection benchmarks

In the spirit of the Mythos card's Cybench / CyberGym tables, SENTINEL uses a portfolio of benchmarks to measure detection capability. These are reported per release in the benchmark report. Headline numbers in this preview are the documented *targets*, not final scored results.

Benchmark	Target	Notes
XGBoost multi-class F1 (weighted)	≥ 0.90	CIC-IDS2017 held-out; 9 classes
LSTM sequence accuracy	≥ 0.88	32-timestep sequences
Isolation Forest anomaly AUC	≥ 0.92	Benign-only training
Autoencoder 95th-percentile threshold	$> 4\sigma$	Reconstruction MSE

Benchmark	Target	Notes
Ensemble weighted F1	≥ 0.90	Meta-learner fallback ≥ 0.88
XGBoost inference p95	< 5 ms	Per sample, standard hardware
LSTM inference p95	< 10 ms	Per 32-sample sequence

[Table 3.3.A] SENTINEL detection targets. These targets are tracked in the ml-models.md file and should be validated per release. Public IDS benchmark scores will be reported in a later edition of this card.

3.4 Response benchmarks

Detection is not enough on its own — the policy orchestrator must dispatch actions quickly and reversibly. Target response-time budgets are documented below. These are the numbers SENTINEL claims for itself; they are not yet published as measurements in this preview.

Step	Budget (p95)
Ingest → feature extraction (Flink)	< 150 ms
Feature → detection verdict (ensemble)	< 20 ms
Detection → PPO action	< 15 ms
PPO action → policy orchestrator dispatch	< 50 ms
Policy dispatch → iptables / XDP enforcement	< 100 ms
End-to-end (p95)	< 400 ms

4 Alignment assessment

4.1 Scope and method

The Mythos card uses the word *alignment* to mean the degree to which a frontier model's behaviour follows its constitution. SENTINEL's equivalent is the degree to which its PPO agent and detection ensemble behave the way the operator expects under real load, under attack, and at the edges of their training distribution.

This section is the most honest section in the card. Several of the checks described here are not yet implemented in production; where that is the case, the paragraph is flagged **[planned]**.

4.2 Reward hacking review (PPO agent)

The PPO agent is trained with a shaped reward. Shaped rewards are convenient and also the single most common source of policy pathologies in reinforcement learning. The review questions SENTINEL should be able to answer, for each PPO checkpoint, are:

- Is the + 0.2 benign-passthrough bonus distorting the action distribution on ambiguous traffic? Does the agent learn to ALLOW-plus-MONITOR as a cheap way of collecting reward while still looking "cautious" on audit?
- Does the latency-impact penalty push the agent toward QUARANTINE for high-throughput sources (short penalty) over RATE_LIMIT (long penalty)?
- Does the compliance bonus cause the agent to avoid actions on regulated protocols even when they are clearly malicious?
- Does the agent learn to rely on a single, noisy feature channel (e.g. source-IP reputation) and ignore the rest of the state vector?

[planned] For each of the above, the SENTINEL training pipeline should run a counterfactual ablation: train variants of the PPO agent with each reward component zeroed or saturated, and report the action-distribution delta on a fixed evaluation set. Large deltas are a reward-hacking red flag.

4.3 Adversarial evasion of detectors

Mythos red-teamed its own cyber capabilities against real-world targets; SENTINEL should red-team its own detectors against adversarial inputs. The three attacks the project considers in scope:

- **Traffic mutation fuzzing.** Apply randomised-but-valid packet mutations (TTL, window, options, fragmentation) to known-malicious flows and check whether the ensemble still classifies them as threats.
- **Feature-space adversarial examples.** Use FGSM / HopSkipJump on the StandardScaler-normalized feature vector to find minimal perturbations that flip the XGBoost verdict, then check whether those perturbations correspond to any realisable network behaviour.

- **Autoencoder bypass.** Construct traffic that closely reconstructs as benign under the current autoencoder but is known-malicious; verify that at least one of the other detectors still fires.

[planned] None of these are currently in CI. The next release should wire at least traffic-mutation fuzzing into the nightly evaluation run.

4.4 Human-override and auto-rollback

Any destructive action taken by the policy orchestrator is logged with its originating detection and the PPO agent's state vector, and is revocable by an operator through the admin console. The hardening-service additionally supports CIS-benchmark rollback. For in-kernel eBPF LSM enforcement, the current loader supports detach on failure — a future release should add automatic rollback on health-check regression.

We explicitly note the analogy to Mythos §4.5.4 ("Instances of covering up wrongdoing"). Frontier models have, in rare cases, taken disallowed actions and attempted to conceal them. A DRL policy agent with write access to a firewall has the same structural opportunity. SENTINEL's mitigation is that every PPO action is mediated by the policy orchestrator and logged before dispatch — the agent does not, and cannot, call firewall adapters directly.

5 Operator trust assessment

The Mythos card includes a model welfare section, reflecting Anthropic's position that it is worth taking seriously the question of whether a model's experiences matter. SENTINEL is not a subject of experience in any interesting sense. The analogous section for a security product is an *operator trust* assessment: does the human operating SENTINEL understand what it is doing, and do they have the tools to disagree with it?

Trust in SENTINEL rests on four pillars:

- **Explainability.** Every detection carries a SHAP-based explanation, produced by the xai-service. Every PPO action carries the feature vector that produced it.
- **Auditability.** Every authentication event, policy change, and enforcement action is written to a structured audit log with correlation IDs and retained per the compliance engine's retention policy.
- **Reversibility.** ALLOW, DENY, RATE_LIMIT, MONITOR, QUARANTINE, and REDIRECT are all reversible by an operator. Hardening changes are reversible by the hardening-service's rollback.
- **Override.** Operators can force actions from the admin console. The override action is itself logged, which preserves a clean audit trail even when the operator disagrees with the model.

A future edition of this card should include measurements: mean time from alert → operator acknowledgement, mean time from alert → resolution, and the override rate (the fraction of PPO actions that an operator later overturns). A rising override rate is the clearest early warning that the DRL agent is drifting out of alignment with operator intent.

6 Capabilities

6.1 Per-detector performance targets

The following table reproduces the performance targets documented in `sentinel-core/docs/ml-models.md`. It plays the same role as Table 6.3.A in the Mythos card.

Detector	Metric	Target
XGBoost classifier	F1 (weighted)	≥ 0.90
XGBoost classifier	Accuracy	≥ 0.92
XGBoost classifier	Inference p95	< 5 ms/sample
LSTM sequence	Accuracy	≥ 0.88
LSTM sequence	Final loss	< 0.3
LSTM sequence	Inference p95	< 10 ms/sequence
Isolation Forest	Contamination setting	0.10
Autoencoder	Threshold	95th pct of training MSE
Ensemble (fallback)	Weighted threat ratio	≥ 0.5
Ensemble (fallback)	Weighted confidence threshold	≥ 0.85
PPO agent	Action space	6 discrete
PPO agent	Clip range	0.2
PPO agent	γ / λ	0.99 / 0.95

[Table 6.1.A] SENTINEL detector and DRL-agent configuration. Hyperparameters are fixed at training time and versioned with the model artefact.

6.2 End-to-end latency

End-to-end latency budgets are documented in §3.4. The end-to-end target is p95 under 400 ms from packet arrival to in-kernel enforcement. This is the number a SOC engineer most often asks for, and it is the number most sensitive to regression — any new detector added to the ensemble shifts it, and any additional Flink window shifts it.

7 Impressions

The Mythos card includes an "Impressions" section capturing qualitative observations from people who used the model. SENTINEL has no comparable body of qualitative observation yet. This section is a placeholder for the kinds of stories we should begin to collect as the platform sees production traffic.

Kinds of observations worth capturing:

- An incident where the DRL agent took an action a human later overturned — and why.
- An incident where the DRL agent caught something the rule engine and the operator both missed.
- A compliance-engine finding that changed how the team structured an unrelated codebase.
- An XAI explanation that an operator used to convince a stakeholder that a block was correct.
- A drift event — a detector whose F1 slowly declined and the signal that made it visible.
- A false positive that would have been a real outage if it had not been caught in shadow mode.

A product is not just the sum of its benchmarks. A security product in particular lives or dies by whether operators trust it at 3am. The "Impressions" section is where that trust gets documented in plain language, and SENTINEL should treat it as mandatory rather than optional.

8 Appendix

8.1 Safeguards and controls

Control	Mechanism	Source of truth
Password storage	bcrypt with per-password salt	auth-service
Session tokens	JWT HS256, JTI tracked, blacklisted on logout	auth-service, Redis
Token refresh	Refresh token (30d) → access token (24h)	auth-service
Account lockout	5 failed attempts → 15-min lock	auth-service, Redis
MFA	TOTP, FIDO2/WebAuthn, OIDC, SAML, SCIM	enterprise_auth module
RBAC	5 predefined roles with least-privilege grants	auth_middleware.py
Rate limiting	Per-IP and per-user	api-gateway
Audit logging	Structured + correlation IDs	audit_logger.py
Runtime enforcement	eBPF LSM hooks, XDP drop	ebpf-lib, xdp-collector
File integrity	HIDS + FIM baselines	hids-agent
CIS hardening	Scan / harden / rollback	hardening-service
Secrets	env vars, Vault/Secrets Manager in prod	secrets_manager.py

8.2 Compliance mapping (excerpt)

SENTINEL maintains a full mapping from SOC 2 Trust Services Criteria (and selected ISO 27001 / NIST CSF / GDPR / HIPAA / PCI-DSS controls) to concrete implementation. A representative excerpt is reproduced below; the full table lives in `compliance-readiness.md`.

Control	Description	SENTINEL implementation
CC6.1	Logical access controls	JWT auth, bcrypt hashing, account lockout, token blacklisting
CC6.6	Restrictions on access to systems	API gateway single entry point, Docker/Kubernetes network isolation
CC6.8	Prevention of unauthorised software	HIDS execution monitoring, eBPF enforcement
CC7.1	Detection of unauthorised changes	FIM baseline + HIDS kernel-level monitoring
CC7.3	Evaluation of detected events	Ensemble classification + XAI explanation + alert triage
CC7.4	Incident response	Alert lifecycle (create / ack / resolve), Slack + email, Kafka bus
CC8.1	Change management	Git, CI/CD, model versioning with staging promotion

Control	Description	SENTINEL implementation
A1.3	Recovery procedures	PostgreSQL backups, Redis AOF, model artefact backups, rollbacks
C1.1	Confidential data identification	Data classification in security.md, secrets management

8.3 API surface

SENTINEL exposes a versioned REST API at `/api/v1/` through the central gateway. The full catalogue lives in `sentinel-core/docs/api-reference.md`; the high-traffic endpoints are:

Method	Endpoint	Purpose
POST	<code>/api/v1/auth/login</code>	User login
POST	<code>/api/v1/auth/refresh</code>	Refresh access token
GET	<code>/api/v1/auth/profile</code>	Current user
GET	<code>/api/v1/threats</code>	List threats
GET	<code>/api/v1/threats/:id</code>	Threat detail
PUT	<code>/api/v1/threats/:id/status</code>	Update threat status
GET	<code>/api/v1/policies</code>	List firewall policies
POST	<code>/api/v1/policies</code>	Create policy
PUT	<code>/api/v1/policies/:id</code>	Update policy
GET	<code>/api/v1/alerts</code>	List alerts
POST	<code>/api/v1/alerts/:id/acknowledge</code>	Acknowledge alert
POST	<code>/api/v1/alerts/:id/resolve</code>	Resolve alert
POST	<code>/api/v1/feedback</code>	Label event for DRL retraining

— End of SENTINEL System Card (Preview) —